BC FERRIES · QE COMMUNITY OF PRACTICE

QE Connect 1.0.0

Security review pack and SOC 2 control mapping

Release v1.0.0 (git d0ad4a4) · Assessment date 27 October 2026

Self-assessment, not a SOC 2 report

A SOC 2 report is an independent attestation by a licensed CPA firm on how an **organization** designs and operates its controls over a period. It cannot be produced for a piece of software. This document is the application-level evidence a security team reviews: how QE Connect supports each SOC 2 Trust Services Criterion, the results of a vulnerability scan and code review, the findings, and the controls BC Ferries must operate itself. It has not been reviewed or attested by an auditor.

Scope	QE Connect 1.0.0 application: Python backend, web interface, respondent survey, email delivery, packaging (start scripts, Docker files). Excludes the hosting server, network, Microsoft 365 tenant and BC Ferries processes.
Method	Source code review of every backend module and the web interface; dependency scans (pip-audit 2.10.1, npm audit); search for outbound network calls; 24 automated tests on SQLite and PostgreSQL 16; browser test of the full flow; targeted tests to confirm findings.
Prepared by	_____
Reviewed by	_____
Version	1.0 · 27 October 2026

1. Summary

QE Connect is in good shape for a **pilot with test data on a laptop**. Before it handles real respondents on the BC Ferries network, a short security release (1.0.1) should fix the seven items under **Fix before go-live**, and BC Ferries IT should put the hosting controls in section 6 in place.

	What we found
Strengths	No known vulnerabilities in any of the 33 Python packages or the web interface packages. Passwords hashed with scrypt; random session tokens stored hashed, in HttpOnly SameSite=Strict cookies; a custom header required on every change; strict Content Security Policy and security headers; three roles checked on the server; survey links are 144-bit random tokens that can be cancelled; answers validated on the server; spreadsheet formula injection neutralised in downloads; mail secrets kept out of the portal and database; the only outbound connections are to the configured email route; API docs off by default.
Fix before go-live	SEC-01 to SEC-07: email queue can stall on a malformed application name; uploaded workbooks parsed without a hardened XML parser; no request size limit (including the public survey); survey links written to the server log; no multi-factor sign-in; security events not fully logged; HTTPS left entirely to hosting.
Plan with BC Ferries	Hosting on a BC Ferries server with an internal certificate, disk encryption and backups; a Microsoft 365 app registration limited to one mailbox; joiner/leaver process for team accounts; privacy notice and retention period for respondent data.
Overall	**Pilot-ready. Production-ready after release 1.0.1 and the hosting controls.** 0 critical, 2 high, 5 medium and 9 low findings.

2. System description

QE Connect lets the BC Ferries QE Assessment team send a quality-practice survey to the named respondent for each application and collect the answers. The team signs in to a portal; respondents open a personal link from an email and do not sign in.

Components

Component	Technology (version)	Role
Web server and API	Python 3.10+ (tested 3.10.20 and 3.13), FastAPI 0.143.0, Starlette 1.7.0, Uvicorn 0.54.0, Pydantic 2.14.0	Portal and survey API, serves the web interface
Data access	SQLAlchemy 2.0.54, Alembic 1.20.0 (migrations run at start-up)	Schema and queries
Database	SQLite (default, one file in the data folder) or PostgreSQL 16 via psycopg 3.3.6	All application data
File handling	openpyxl 3.1.5, python-multipart 0.0.32	Excel/CSV imports, Excel downloads
Email	Microsoft Graph via msal 1.39.0, or Python smtplib (SMTP relay)	Invitations, reminders, test emails
Web interface	React 18.3.1, TanStack Query 5.104.1, built with Vite 6.4.4 and TypeScript 5.9.3	Portal and respondent survey; no third-party scripts or fonts
Packaging	start.bat / start.sh (private .venv), Dockerfile (non-root, health check), docker-compose with PostgreSQL	Install and run

Data held

Data	Examples	Classification
Survey link tokens	Personal link in each invitation (bearer credential for one survey)	Secret
Mail secrets	Graph client secret or certificate key, SMTP password: in the server .env only, never in the database or portal	Secret
Respondent details	Names and work email addresses of respondents	Confidential (personal information)
Survey answers	Application profile, criticality, team size, testing practice	Confidential (business)
Team accounts	Names, work emails, scrypt password hashes, roles	Confidential
Sent email copies	Subject, body (including survey link), status	Confidential
Applications register, question bank, LOBs	Application names, project IDs, delivery teams, questions	Internal
Activity log	Who did what and when (changes, sends, downloads, submissions)	Internal

Data flows and boundaries

#	From → To	What and how
1	Team browser → QE Connect	Portal pages and API over HTTP(S); session cookie; custom header on changes. HTTPS is provided by the hosting reverse proxy.
2	Respondent browser → QE Connect	/s/<token> page and /api/s/<token> API; no account; answers autosaved; submit validated on the server.
3	QE Connect → Microsoft 365 or SMTP relay	Graph: HTTPS to login.microsoftonline.com and graph.microsoft.com. SMTP: STARTTLS or TLS with certificate verification (plain only if chosen for an internal relay).
4	Microsoft 365 / relay → respondent mailbox	Outside QE Connect: BC Ferries email infrastructure.
5	QE Connect ↔ database	Local SQLite file, or PostgreSQL over the network (TLS per the database URL).
—	Anything else	None. Code search found no other outbound calls; the web interface loads nothing from outside QE Connect.

3. SOC 2 Trust Services Criteria mapping

Supported: QE Connect provides the control. **Partial**: QE Connect provides part of it; the gap is a finding or a BC Ferries control. **Client control**: BC Ferries operates it (see section 5).

Criterion	What it asks	Status	How QE Connect meets it
CC6.1	Logical access security	**Partial**	Local accounts; scrypt password hashing; 10-character mixed password rule; random session tokens stored as SHA-256 hashes; HttpOnly, SameSite=Strict cookies; 12-hour sessions; sign-in throttling. Gap: no MFA (SEC-05), throttle held in memory (SEC-09).
CC6.2	Registering and removing users	**Supported**	Only administrators add, change, deactivate or remove team accounts; deactivation and password resets end active sessions; the last administrator can't be removed. Survey links can be cancelled. BC Ferries runs the joiner/leaver process.
CC6.3	Role-based access, least privilege	**Supported**	Admin, editor and viewer roles enforced on every API call on the server; email delivery, team and backups are admin only; viewers are read-only. All team members see all applications (SEC-15).
CC6.4	Physical access	**Client control**	Hosting server, laptop or data centre.
CC6.5	Disposal of data and assets	**Partial**	Applications, survey links and responses can be deleted in the portal. Disk and backup disposal is BC Ferries' responsibility.
CC6.6	Protection at the system boundary	**Partial**	Listens on this computer only by default; strict CSP, X-Frame-Options DENY, no-referrer, nosniff; custom request header blocks cross-site changes; server header off; API docs off. Gaps: no request size limit (SEC-03), no host-name check (SEC-12).
CC6.7	Protecting data in transit	**Partial**	Email routes use TLS with certificate checks. Browser traffic relies on HTTPS at the reverse proxy; no built-in HTTPS or HSTS (SEC-07).
CC6.8	Preventing malicious or unauthorized software	**Partial**	Uploads limited to 10 MB of .xlsx/.csv/text; no macros executed; formula injection neutralised in downloads; no third-party scripts. Gap: no hardened XML parser for workbooks (SEC-02).
CC7.1	Detecting vulnerabilities and configuration changes	**Partial**	pip-audit and npm audit clean at release; pinned top-level dependencies. Gaps: scans are manual, transitive packages not locked (SEC-11, SEC-13).
CC7.2	Monitoring for anomalies	**Partial**	Activity log of sign-ins, changes, sends, downloads and submissions; failed emails flagged; health endpoint. Gap: failed and blocked sign-ins not logged, no security log view (SEC-06).
CC7.3	Evaluating security events	**Client control**	Regular review of the activity log and server logs.
CC7.4	Responding to incidents	**Partial**	Tools in the app: cancel a survey link, deactivate an account, reset passwords (also from the command line), reopen or delete a response. Incident process is BC Ferries'.
CC7.5	Recovering from incidents	**Partial**	Backup download and restore in the portal; schema migrations with tested downgrade; data in one folder. Running and testing backups is BC Ferries'.

Criterion	What it asks	Status	How QE Connect meets it
CC8.1	Change management	**Partial**	Git history and tags; 24 automated tests on SQLite and PostgreSQL; browser test; migrations tested both ways; changelog. Gap: no automated build pipeline or approval gate (SEC-13).
A1.2	Backup and recovery infrastructure	**Partial**	Backup/restore feature and copy-the-folder backups; Docker volumes. Scheduling, storage and restore tests are BC Ferries'.
C1.1	Identifying and protecting confidential information	**Partial**	Confidential data identified (section 2); access limited to signed-in team; links are random; downloads need sign-in. Gaps: survey links in server log (SEC-04), backup files unencrypted (SEC-14).
C1.2	Disposing of confidential information	**Client control**	Retention period and deletion after the assessment.
PI1.2–1.4	Processing integrity	**Supported**	Answers checked on the server against the question bank: unknown options dropped, required questions and show-if rules enforced, exclusive options applied; a submitted response is locked until the team reopens it; every change logged.
P1–P8	Privacy	**Partial**	Collects only names and work emails of respondents; the survey states the name is used only for follow-up; no tracking or third parties. Notice, retention and privacy assessment under applicable BC privacy law are BC Ferries'.

4. Findings

Severity reflects risk once QE Connect holds real respondent data on the BC Ferries network. Items marked **Confirmed** were reproduced with a test.

ID	Severity	Finding	Recommended action
SEC-01	Medium	Email queue stalls on a line break in an application name. A name containing a line break (possible via paste or import) makes the email header invalid; the error isn't caught, so that email and every later one stay queued. Confirmed.	Remove line breaks from names and subjects; catch any error per email, mark it Failed with the reason and move on.
SEC-02	Medium	Uploaded workbooks parsed without a hardened XML parser. defusedxml isn't in the requirements, so openpyxl uses the standard parser; decompressed size isn't capped. A crafted .xlsx from a signed-in editor could exhaust memory. Confirmed (absent from the release install).	Add defusedxml; cap uncompressed workbook size and sheet count; reject before parsing.
SEC-03	Medium	No request size limit. JSON bodies on every endpoint, including the public survey endpoints that need no sign-in, are read in full, so a very large request could exhaust memory.	Reject bodies over a limit (for example 1 MB for JSON, 10 MB for uploads) before reading them.
SEC-04	Medium	Survey links written to the server log. The access log records each /api/s/<token> request, so anyone who can read the logs can open and change a respondent's survey. Confirmed.	Mask tokens in access logs; keep log files access-controlled.
SEC-05	High	No multi-factor sign-in for team accounts. A stolen password gives full access to responses and respondent details, and admins can change email delivery.	Add optional or required TOTP authenticator codes, with admin reset and recovery; or move sign-in to BC Ferries Entra ID.
SEC-06	Medium	Security events not fully logged. Successful sign-ins are logged, but failed and blocked sign-ins, sign-outs and session expiry aren't, and there's no filtered security view or export.	Add a security event log (sign-in success/fail/blocked, sign-out, password and role changes, exports, deletions) with an admin view.
SEC-07	High	HTTPS left entirely to hosting. QE Connect has no built-in HTTPS and sends no HSTS header; if deployed without a correctly configured proxy, passwords and survey links travel in clear text.	Optional built-in HTTPS (certificate and key settings), HSTS and Secure cookies automatically over HTTPS; document the proxy setup.
SEC-08	Low	No idle timeout. Sessions end after 12 hours regardless of activity.	End sessions after a configurable idle period (for example 30 minutes).
SEC-09	Low	Sign-in throttle kept in memory. It resets on restart; behind a reverse proxy every user shares the proxy's address, so one person's failures can block everyone.	Count failures from the security log per account and per real client address; add a trusted-proxy setting.
SEC-10	Low	Respondent's reference number is the first six characters of their link token, revealing part of the secret.	Generate a separate reference number.
SEC-11	Low	Indirect Python packages aren't locked to exact versions or hashes, so two installs can differ.	Ship a lock file with hashes; install with --require-hashes.
SEC-12	Low	No host-name check. A laptop install could be reached through DNS rebinding from a malicious website.	Allow only configured host names.

ID	Severity	Finding	Recommended action
SEC-13	Low	Vulnerability scans and tests run by hand; no automated pipeline.	Run tests, pip-audit and npm audit on every change and weekly (for example GitHub Actions and Dependabot).
SEC-14	Low	Backup files contain respondent details and live survey links and aren't encrypted.	Warn in the portal; offer password-protected backups; BC Ferries stores them securely.
SEC-15	Low	Every team member sees every application and response; no restriction by line of business.	Confirm with the assessment team; add per-LOB access if needed.
SEC-16	Low	Survey link tokens are stored readable in the database (needed to resend reminders), so database or backup access allows opening surveys.	Accept with SEC-14 controls, or store hashed and issue a new link on each reminder.

Fix before go-live: SEC-01 to SEC-07. The others can follow in a later release or be accepted with the BC Ferries controls in section 5.

5. Controls BC Ferries operates

QE Connect relies on these complementary user entity controls. A reviewer should confirm each is in place before go-live.

Area	Control
Hosting	Run QE Connect on a BC Ferries server or VM, not a laptop, for the real survey; patch the operating system and Python; restrict administrator access to the server.
HTTPS	Internal DNS name and a certificate from the BC Ferries internal certificate authority; reverse proxy on port 443; QEC_SECURE_COOKIES=true; no exposure to the internet unless approved.
Data at rest	Encrypted disk for the data folder or PostgreSQL storage; database credentials kept in the server .env with restricted file permissions.
Backups	Scheduled backups of the data folder or database, stored securely, with a restore test before go-live and periodically after.
Email	Entra ID app registration with Mail.Send limited to the QE Connect mailbox by an application access policy; certificate preferred to a secret; credential expiry tracked and rotated; shared mailbox monitored for replies.
Team access	Accounts only for the assessment team; deactivate leavers promptly; review accounts and roles at least quarterly; at least two administrators.
Monitoring	Review the activity log and server logs regularly; protect and retain logs per BC Ferries policy.
Privacy	Privacy notice for respondents; assessment under applicable BC privacy law; retention period; delete applications and responses once the assessment closes.
Updates	Apply QE Connect security releases; keep dependencies current (see SEC-13).

6. Path to production

Step	Who	Outcome
1. Security release 1.0.1	QE Connect	SEC-01 to SEC-07 fixed (plus quick lows SEC-08 to SEC-12); this pack reissued with each finding's status.
2. Server and HTTPS	BC Ferries IT	Server or VM, DNS name, internal certificate, reverse proxy, service, backups, disk encryption.
3. Email connection	BC Ferries IT	App registration and access policy (or SMTP relay), shared mailbox; test email passes.
4. Privacy review	BC Ferries privacy	Notice text, retention period, approval to collect respondent details.
5. Pilot	Assessment team	Two or three applications end to end; download and check responses.
6. Full send	Assessment team	Invitations to all respondents; reminders; export at close; data deleted per retention.

Appendix A. Method and evidence

- **Code review**: authentication, sessions and roles (security.py, routers/auth.py, routers/users.py); request checks and headers (main.py); uploads and parsing (routers/setup.py, services/importer.py); survey access by token (routers/public.py); email routes and queue (services/mail.py); downloads and backups (services/export.py, services/sample.py); configuration defaults (config.py, .env.example); Dockerfile; web interface source.
- **Outbound calls**: searched all backend and web interface code for HTTP clients, sockets and smtplib. Only the Microsoft Graph and SMTP email routes connect out. The built web interface references no external hosts.
- **Dependency scans** (27 October 2026): pip-audit 2.10.1 on the resolved runtime requirements including the PostgreSQL driver, 33 packages, no known vulnerabilities. npm audit (production and full), 0 vulnerabilities. react-router-dom was removed during the build because every 6.x release carries an advisory.
- **Tests**: 24 automated tests (sign-in, roles, request header, throttling, imports, show-if rules, the full send-respond-download loop, SMTP and Graph routes, failures and retries, backup round trip) pass on SQLite and on PostgreSQL 16, and on Python 3.10.20 and 3.13. Migrations upgraded and downgraded on both databases. A browser test ran setup, import, email to a test mail server, a respondent completing the survey on a phone-sized screen, and download.
- **Confirming findings**: SEC-01 reproduced with a test (queue left the email queued after an uncaught error); SEC-02 checked in a fresh install from the release zip (defusedxml absent); SEC-04 seen in the server access log.
- **Not covered**: penetration testing by a third party, the hosting environment, the Microsoft 365 tenant, and the Docker image build (no Docker engine was available).

Appendix B. Pinned components

Package	Version	Package	Version
fastapi	0.143.0	openpyxl	3.1.5
starlette	1.7.0	python-multipart	0.0.32
uvicorn	0.54.0	msal	1.39.0
pydantic	2.14.0	psycopg[binary] (optional)	3.3.6
sqlalchemy	2.0.54	react / react-dom	18.3.1
alembic	1.20.0	@tanstack/react-query	5.104.1
cryptography (via msal)	50.0.2	vite / typescript (build only)	6.4.4 / 5.9.3